CAWG–TRQP

Verifier Reference Implementation

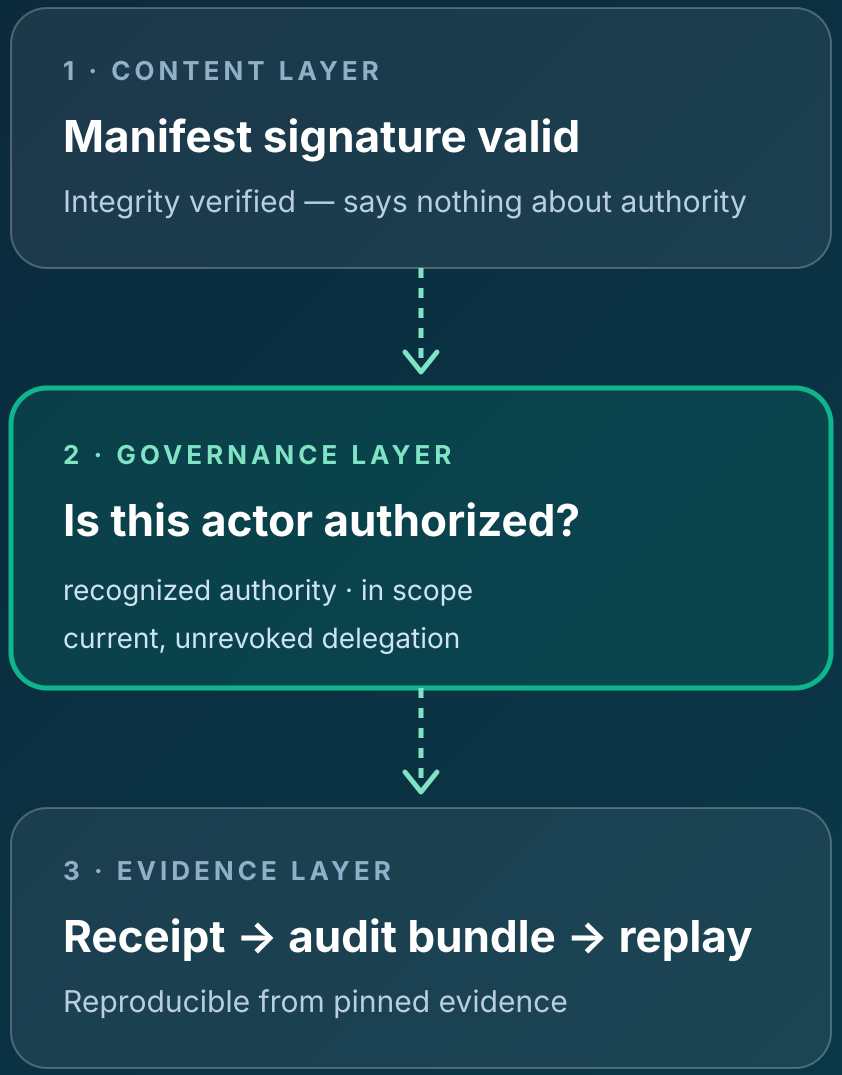
From content provenance to verifiable trust decisions

v0.20.0 · released 3 Nov 2026

Pilot-ready reference implementation

22	26	215	3
walkthroughs	JSON Schemas	passing tests	verifier profiles

Explainer deck v4 · non-normative. The implementation, schemas, OpenAPI contract and profiles are authoritative where wording differs.



THE PROBLEM

A valid signature proves signing. It doesn't prove authority.

Signing is not authorization

A valid CAWG/C2PA signature shows who signed a manifest — not whether that actor was permitted to act on this resource, for this purpose, right now.

Decisions must be replayable

Auditors and appeals need to reproduce a decision from pinned evidence after the fact — not take a log line on trust.

Policy lives somewhere else

Provenance and governance policy sit in different systems. Without a machine-readable link between them, enforcement is manual and inconsistent.

Many registries, one verifier

Federated registries, gateways and offline snapshots create routing ambiguity unless a common protocol binds them.

The real question: was this actor — under a recognized authority, within scope, with a current and unrevoked delegation — authorized to do *this*, and can we prove it later?

STANDARDS BOUNDARY

Two standards, two questions, one seam.

This repository joins validated provenance signals to governed decisions. It does not extend or reinterpret either specification.

CAWG / C2PA

What happened to this content?

Tamper-evident provenance: capture, edits, ingredients, assertions and the cryptographic integrity of the manifest chain.

→

THIS REPOSITORY

Executable reference implementation

Turns a minimal integration signal into a scoped, replayable decision: may **this actor** perform **this action** on **this resource**, under a recorded policy and trust state?

←

TRQP

Is this actor authorized for this action?

Recognized authority, delegated scope, and a governed, revocable decision about whether an action may proceed.

Not a specification. Authoritative only for its own code, schemas, profiles and fixtures. It does not govern CAWG, C2PA or TRQP.

Provenance is not truth. A positive result means requirements were met — not that content is factually true, owned, entitled or clinically valid. That judgment stays with the relying organization.

EVERY DECISION IS BOUND TO

actor · action · resource · recorded policy · trust state · point in time — so it can be replayed, appealed and corrected without ambiguity.

THE STACK

One protocol, accountable layers across repositories.

Authority is distributed by design. No single repository governs the whole decision — each layer publishes its own evidence.

NORMATIVE

TRQP Protocol

Upstream specification

Defines authority, recognition and query semantics

OUTPUT

Protocol specification

TRQP-TSPP

`v0.15.0`

Implemented against

OUTPUT

Posture report

THIS REPO

Reference Implementation

`v0.20.0`

Verifier, gateway, profiles, replay

OUTPUT

Decision receipt + audit bundle

Conformance Suite

`v1.7.0`

Receives implementation evidence

OUTPUT

Conformance report

Assurance Hub

`v1.10.0`

Aggregates evidence across layers

OUTPUT

Combined assurance manifest

Semantic & schema authorities (pinned): Trust Systems Meta-Model `v0.24.0` · Trust Infrastructure Schemas `v0.14.1`. Release train `trqp-2026-08`.

Pins are evidence, not endorsement. `portfolio/integration-contract.json` declares invalidation triggers; a release here does not imply upstream adoption.

WHAT IT GUARANTEES

What it guarantees — and what it doesn’t.

Authority & recognition

Policy feeds, trust anchors and recognition responses establish who is recognized before any action is evaluated.

Delegation & action scope

Authorization requests, gateway routes and context profiles bind a decision to one actor, action and resource.

Enforcement & revocation

Live, delta, snapshot and fail-closed descriptor policies keep enforcement current under partial connectivity.

Auditability

Stable reason codes, decision receipts and signed audit bundles make every decision inspectable.

Reproducibility

Pinned replay bundles and trusted replay roots re-derive a decision deterministically — the basis for appeal.

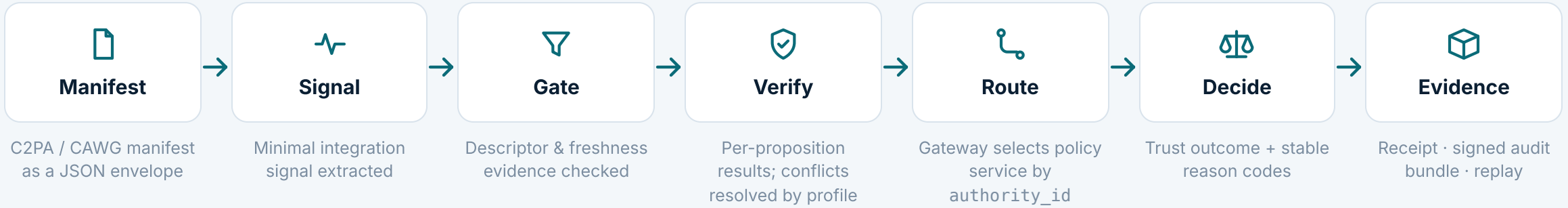
Privacy controls

Minimization, retention, redaction and rights profiles; the audit endpoint returns a redacted minimal receipt by default.

⚠ **Does not assert:** production certification · independent assurance · factual-truth determination · ownership adjudication. Deployment-specific legal, privacy and operational controls remain the adopter’s responsibility.

HOW IT WORKS

From manifest to verified, replayable decision.



CONTENT LAYER | POLICY & GOVERNANCE LAYER | EVIDENCE & AUDIT LAYER

PARSER BOUNDARY

Manifests enter through an adapter contract. JSON and C2PA-style JSON envelopes are processed today; a redistribution-safe binary C2PA backend is deliberately deferred. An optional, bounded `c2patool` subprocess adapter exists as an experimental feasibility interface.

OPTIONAL PROCESS APPRAISAL

Process evidence (for example human-assisted authoring) is appraised at the verifier stage and reported separately — it is never folded into a single success flag, and malformed or non-finite process evidence is rejected at the typed boundary.

VERIFIER PROFILES

Three profiles, two overlays, no forked code.

Values below are read directly from `profiles/*.json`. Overlays compose onto a base profile without forking it.

PROFILE	REVOCATION	NETWORK / POLICY FAILURE	STALE · DEGRADED	DESCRIPTOR POLICY	EVIDENCE
edge Offline-tolerant	snapshot · ≤ 24 h warn	`fail_open`	stale → defer degraded → degraded	policy, revocation, gateway: observe snapshot: **fail**	no bundle by default
standard General-purpose	delta · ≤ 1 h warn	`fail_open`	stale → defer degraded → degraded	all feeds: observe	audit bundle emitted
high_assurance Regulated / evidentiary	live · ≤ 5 min **hard fail**, delta required	`fail_closed`	stale → **deny** degraded → **reject**	policy, revocation, gateway: **fail** snapshot: warn	bundle + attestation + feed descriptors required

COMPOSABLE OVERLAYS

`evidence_attested`	Require audit-bundle emission with attestation.
`freshness_strict`	Force live policy (≤ 5 min); fail closed when policy can't be obtained.

PRIVACY PROFILES

`minimal-receipt` `replay-bundle` `regulated-evidence`

Schema-backed by `schemas/verification-profile.schema.json`.

EVIDENCE & ASSURANCE

Decision receipts that survive an audit.

Integrity, binding, recognition, authorization, process and freshness are reported separately — never collapsed into one success flag.

```
# python -m cawg_trqp_refimpl.cli \
#   examples/verification_request.json --profile standard
asset_integrity:     verified
assertion_binding:   verified
issuer_recognition:  recognized
actor_authorization: authorized
process_integrity:   verified_high
policy_freshness:    fresh
verification_mode:   cached_online
trust_outcome:       trusted
```

Excerpt of real output on v0.20.0. Each line is a separate proposition with its own evidence.

Isolated per decision

Since v0.19.2, transport, descriptor, cache and revocation evidence is isolated per decision, so one request can’t contaminate another.

Deterministic conflict handling

Explicit assertion-conflict detection, relying-party precedence rules, and an unresolved-conflict state.

Degraded & fail-closed states

`degraded` for warning-level gaps; fail-closed `semantic_guardrail` when required evidence or conflicts fail. High-assurance rejects instead of degrading.

Signed, replayable audit bundles

Pinned policy, revocation and descriptor digests replay from a trusted root; corrections create new evidence — history is never rewritten.

TRUST GATEWAY

Policy routing without re-architecting the verifier.

One verifier can serve many trust registries and policy authorities without embedding registry-specific logic.



Routes by authority

Maps each `authority_id` to a policy service and route label, so federated and multi-registry deployments need no verifier changes.

Auditable mediation

Every mediated lookup records `gateway_id` and route. The gateway cannot redefine the target authority's policy.

Itself governed

Descriptor policy covers policy, revocation, snapshot and gateway-route feeds — observe, warn or fail on stale or untrusted routing state.

Verification modes: `online_full` `cached_online` `offline_snapshot` HTTP service emits structured audit events for verify and audit-bundle routes.

AGENTIC AI ASSURANCE

Agent identity is not agent authority.

Agents are modelled as delegated actors, never trusted identities — bound to a principal, mandate, scope, time window, revocation state and replay evidence.

ROLE	TYPICAL ACTION	ASSURANCE QUESTION
Producer	Generates or transforms content	Was this agent authorized to create or alter this artefact?
Submitter	Packages or submits evidence	Did the principal authorize it to submit this resource, for this purpose?
Verifier	Resolves provenance, authority or policy state	Was it authorized to verify, and are findings reproducible from pinned evidence?
Orchestrator	Calls registries, tools, verifiers or other agents	Can the full delegated action chain be reconstructed and bounded?
Decision agent / proxy	Recommends, executes or acts for a principal	Is decision authority separately delegated, scoped, current and revocable?

EVERY AGENT ACTION CARRIES principal → mandate → scope → validity window → revocation state → replay evidence

Agent role model · Delegation & authority · Verification & decision boundaries · 3 executable cross-sector archetypes

NEW IN V0.20.0 · EXPERIMENTAL

Delegated creation, tested as an experiment.

Repository-local, synthetic and non-normative. Not an adopted CAWG profile, not a production authorization service, not an interoperability demonstration.

Five-world corpus

Brand → agency handover

Scoped AI voice tool

Studio → vendor, multi-hop

Publisher → freelance reporter

Photographer → assistant

Each has an expected historical decision, a current status and an adversarial mutation.

Three further families

Human-to-human manager delegation

Pseudonymous, self-declared uniqueness

Optional professional-licence vouching

A claimed licence or uniqueness statement never authorizes action for a third party.

Mechanics under test

Historical ≠ current authority; later revocation doesn't rewrite a valid signing-time delegation

Ed25519 **statement integrity** under pinned keys

Bounded chain: 3 hops, 30-day links (**test defaults**, not CAWG rules)

```
# reproduce the five-world report (deterministic, schema-validated JSON)
python scripts/run_taskforce_five_world_demo.py --output /tmp/taskforce-report.json
# report flags on v0.20.0:  all_match=true  independent_crypto_verification=false  independent_interoperability=false
```

NEW IN V0.20.0 · ASSURANCE BOUNDARY

Evidence supplied is not authority granted.

Non-elevation invariants: nothing a caller supplies can raise the assured outcome. Unsupported checks report `not_checked`, `unverified` or `indeterminate` — never an implicit PASS.

CALLER-SUPPLIED EVIDENCE	MUST NOT BE INFERRED
Pseudonymous subject identifier	A unique human or verified legal identity
Claim of uniqueness	Independently assured uniqueness
Licence / credential claim	Recognized issuer, or authority to act for a third party
Valid Ed25519 signature	Signer identity or enterprise authority
Organizational affiliation	Authority to bind an enterprise
Authorization at signing time	Independently assured historical authorization

TWO PLANES IN EVERY EXPERIMENTAL RESULT

```
# simulation over caller-normalized data
authority:          authorized
coverage:           credential-backed
# effective assurance for consumers
assured_authority:  indeterminate
assured_coverage:   unverified
assurance_reason:   independent_evidence_
                    verification_unavailable
```

A valid signature proves possession of a key and integrity of the covered statement — nothing more. Adversarial tests include a deliberately fake credential “success”.

NEW IN V0.20.0 · HONEST STATUS

How much is actually demonstrated? The matrices say.

Dispositions come from `conformance/delegated-creator-taskforce-eight-tests.json` and `…-traceability.json`. Nothing is upgraded to “pass”.

EIGHT-TEST ASSESSMENT (TF-01…08)



demonstrated · simulated · partial · unsupported

TRACEABILITY ROWS (DC-01…12)



represented · partial · missing · external

Upstream adoption is **not established** for any row.

Not demonstrated: independent C2PA/TRQP interoperability · trusted signing time · enterprise authority-to-bind · accepted credential issuers. Tracked in open issue **#75**.

ID	PROPOSITION	DISPOSITION
TF-01	Unvouched declaration shown as unverified	simulated
TF-02	Delegator cryptographic signature binds authority	unsupported
TF-03	Low-friction route without certificates	simulated
TF-04	Top tier doesn’t require signing each asset	unsupported
TF-05	Contracts stay private; at most a hash disclosed	partial
TF-06	No automatic network fetching without safeguards	demonstrated
TF-07	Works with C2PA validators and trust lists	unsupported
TF-08	Evaluation against trusted signing time	partial

WALKTHROUGH PORTFOLIO

One governance pattern, twenty-two executable scenarios.

22
indexed walkthroughs, checked in CI

19
sector walkthroughs, each with an Agentic AI Variant

3
cross-sector agentic archetypes

6
lifecycle states per scenario: authorized · scope mismatch · revoked · stale · conflict · corrected

ASSURANCE PATTERN	REPRESENTATIVE WALKTHROUGHS	WHAT IT PRESSURE-TESTS
Publication & public communication	Breaking news · campaign advertising · **official public-safety communications**	Editorial / institutional authority, rapid revocation, incident & channel scope
Rights & commercial authorization	Music distribution · property listings · marketplace	Delegated rights, disclosure scope, platform disposition
Regulated / evidentiary intake	Insurance · medical imaging · legal evidence	Separating intake from substantive adjudication
Field & operational evidence	Body-camera · construction · disaster response · industrial inspection	Device / actor delegation, offline state, safety
Long-lived & correction-sensitive	Scientific imagery · cultural heritage · photo contest	Reproducibility, immutable correction
Constrained / humanitarian	Offline field evidence · warranty & repair	Intermittent connectivity, contested evidence

Bold = added since the v3 deck. 18 machine-readable scenario manifests are discovered and validated in CI.

THREAT MODEL & PRIVACY

Treat governance and evidence as attack surfaces.

THREATS & RISKS

Adversarial assurance model

Trust boundaries and assets → adversary profiles → attack surfaces → adversarial scenarios → preventive, detective and recovery controls → tested residual-risk decisions.

`threat-register.yaml` `adversary-catalog.yaml`
`attack-surface.yaml` `abuse-case-register.yaml`
`residual-risk-register.yaml`

Five adversarial vectors run in `make validate`; key-compromise, federation, replay and scale-abuse threats each have dedicated pages.

PRIVACY & PERSONAL INFORMATION

Governable data handling

Minimized integration signal → verifier → **minimal decision receipt (default)** or privileged replay bundle (explicit scope) → controlled evidence store → human review and redress.

`minimal-receipt.json` `replay-bundle.json`
`regulated-evidence.json`

Evidence sensitivity, retention class, redaction mode and disclosure audience are carried in privacy profiles and audit bundles.

Non-normative. No compliance with any jurisdiction is asserted. A deployer must map these controls to its own purpose, role, data, users, geography and legal obligations.

INTEROPERABILITY

Machine-readable artifacts for stakeholder review.

OpenAPI 3.1 contract

`api/openapi.json` defines six operations, validated against the implementation in CI.

CAWG input contract

Every accepted input shape, field derivation, validation rule and candidate specification gap — plus the API call catalogue.

26 JSON Schemas

Requests, results, receipts, descriptors, profiles, privacy and sector records; the experimental report has its own Draft 2020-12 schema.

Compatibility matrix

Machine-readable alignment with the TRQP protocol, TSPP, conformance suite and assurance hub.

Assurance-suite manifest

`export_conformance_pack.py --check` lets external suites ingest this implementation's evidence.

Portfolio integration contract

Pinned upstream versions, local evidence list and explicit invalidation triggers.

Six HTTP operations: `GET /health` `/trqp/authorization` `/trqp/recognition` `/trqp/gateway/authorization` `/trqp/verify` `/trqp/audit-bundle`

VALIDATION & EVIDENCE

Every capability claim is machine-checked.

Figures below are output of `make validate` on `main` after the v0.20.0 release (3 Nov 2026) — exit code 0.

215
tests passed, across 42 test modules

27/27
JSON examples validate against their schemas

22
walkthrough documents pass diagram and quality gates

12
traceability rows with valid evidence paths

6
API operations match the OpenAPI contract

5
adversarial vectors validated

18
scenario manifests discovered and checked

matches: true
signed audit bundle validates; replay re-derives the decision

REPRODUCE

`make validate` is the single completion gate. Replay independently with `scripts/replay_audit_bundle.py … --trusted-root .`

RELEASE CHECKSUMS

Generated per checkout; the immutable manifest is the `checksums-v0.20.0.json` release asset — not a file on `main`.

ROADMAP

What has shipped, and what remains deliberately open.

RECENTLY LANDED

- ✓ **v0.20.0** · experimental Delegated Creator baseline, non-elevation tests, guarded C2PA adapter
- ✓ **v0.19.2** · per-decision evidence isolation, typed-boundary rejection of malformed process evidence, adversarial vectors, one CI gate
- ✓ **v0.19.1** · TRQP portfolio integration contract with pinned upstream baselines
- ✓ **v0.19.0** · semantic assurance controls and deterministic conflict handling

DELIBERATELY OPEN

- ⚠ **Independent evidence (issue #75)** — real signed assets and live trust endpoints. The next useful work, ahead of more synthetic scenarios.
- ⚠ **Binary CAWG/C2PA backend** behind the adapter boundary, once licensing and determinism are settled
- ⚠ **Production service packaging** — a minimal Dockerfile exists; rate limits, probes and distributed cache remain deployment work
- ⚠ **Cross-repository alignment** of assurance-suite and descriptor-policy contracts

v0.19.0
14 Aug 2026

v0.19.1
20 Aug 2026

v0.19.2
1 Sep 2026

v0.20.0 · this deck
3 Nov 2026

Completion rule: a roadmap item isn't done because code or docs exist — the claimed behavior needs executable validation and reviewable evidence.

RUNNING & CONTRIBUTING

From clone to a verified decision in minutes.

```
# set up
python -m venv .venv && . .venv/bin/activate
pip install -r requirements-lock.txt && pip install -e .

# verify one request under the standard profile
python -m cawg_trqp_refimpl.cli examples/verification_request.json --profile standard

# serve the HTTP API (GET /health → healthy)
python scripts/start_http_service.py \
  --policy-path data/policies.json --revocation-path data/revocations.json \
  --host 127.0.0.1 --port 5000

# reproduce the experimental Delegated Creator report
python scripts/run_taskforce_five_world_demo.py --output /tmp/taskforce-report.json

# run the full gate
make validate
```

Pin the `v0.20.0` tag for reproducibility; `main` may advance with documentation changes.

THEN READ

Operator decision & replay walkthrough → HTTP-to-audit-bundle journey → failure, correction & redress.

GUIDED LEARNING

`docs/guided-learning.md` — three paths, fourteen validated steps.

NON-TECHNICAL OVERVIEW

`docs/NON_TECHNICAL_OVERVIEW.md` for governance, editorial and program roles.

CONTRIBUTING

`CONTRIBUTING.md` · `GOVERNANCE.md` · DCO sign-off required.

THANK YOU

Executable trust, not a claim about trust.

Every statement in this deck is backed by a schema, a profile, a test or a replayable piece of evidence in the repository — and where it isn't demonstrated, the deck says so.

REPOSITORY

`github.com/sankarshanmukhopadhyay/cawg-trqp-verifier-refimpl`

DOCUMENTATION SITE

`sankarshanmukhopadhyay.github.io/cawg-trqp-verifier-refimpl`

STATUS CONTRACT

`PROJECT-STATUS.yaml`
`GOVERNANCE.md` · `ROADMAP.md`

Explainer deck v4 · pinned to **v0.20.0** (3 Nov 2026) · explanatory and non-normative. The implementation, JSON Schemas, OpenAPI contract and profiles remain authoritative when wording differs. Open evidence gaps are tracked in issue #75.